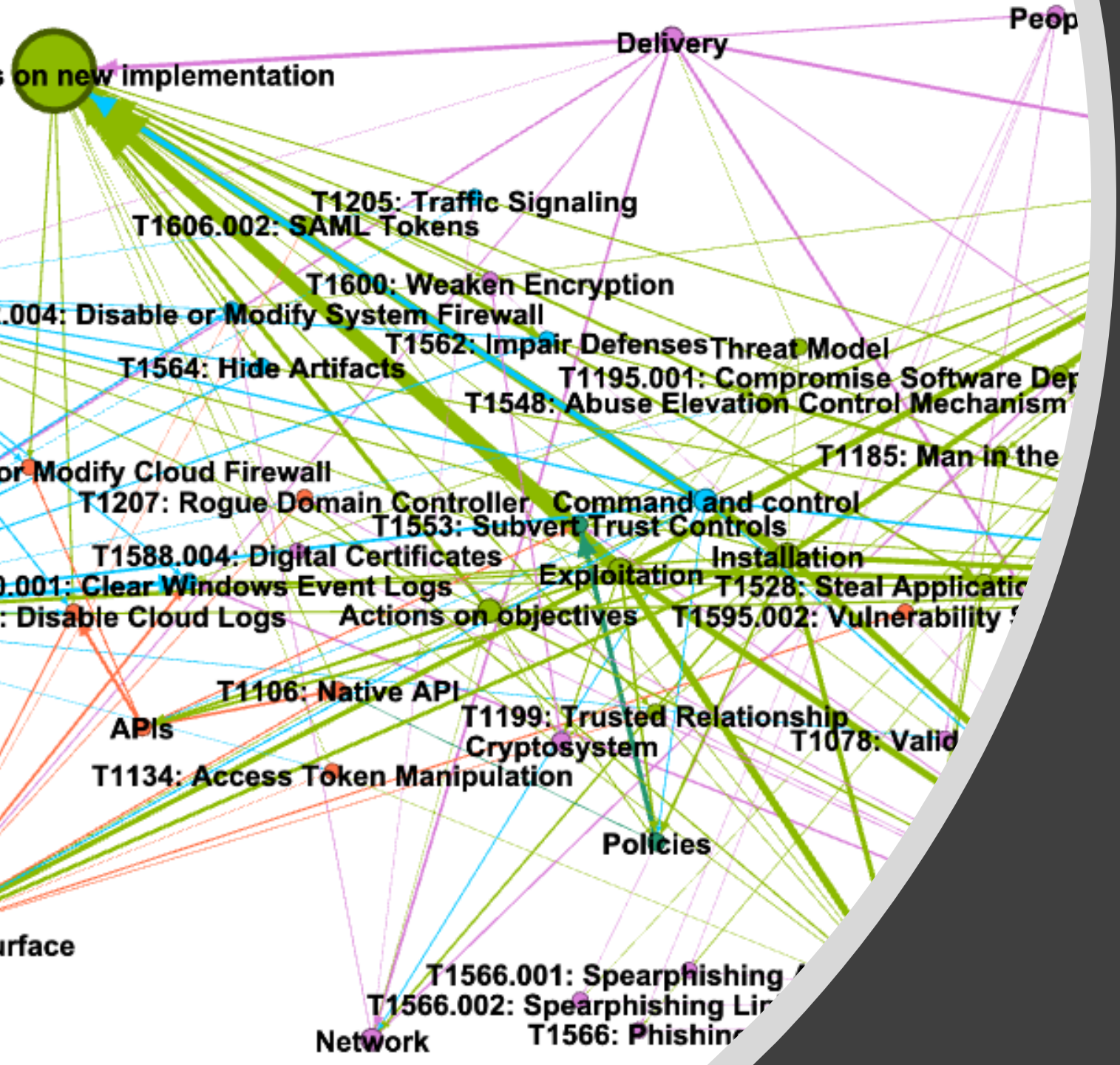


Reflections on Trusting Zero Trust

Why I have Zero Trust in Zero Trust

Tim (Wadhwa-)Brown

Security Research Lead, CX Technology and Transformation Group

Cisco Confidential

Who am I?

@timb_machine

Officially a Security Architect at Cisco

- Powerpoint
- Visio

More interested in applied security

- Developer, UNIX admin, SOC engineer, pen tester, IR responder and more
- Current MEF and MITRE ATT&CK contributor
- Publisher of many bugs – there are no bugs in this talk!

Problems scale, solutions often don't

- Securing the world is going to take all of us!

Dominic Chell
@domchell

This may turn out to be an unpopular opinion, but having red teamed quite a few pure "zero trust", no perimeter, cloud first environments now, this model really needs to be rethought. I can safely say it scares the shit out of me that ppl are deploying this....

9:12 AM · Feb 18, 2021 · Twitter Web App

40 Retweets **6** Quote Tweets **255** Likes

Dom Chell's tweet

Reducing security principles down to buzzwords

Or what we like to call Zero Trust…

Zero Trust according to the analysts

Value claims:

- Data security
- Network security
- Workforce security
- Workload security
- Automation and orchestration
- Visibility and analytics

Cisco Confidential

Zero Trust value claims

Do these all make sense?

Network security

- Secure network access
- Dynamic visibility
- Network segmentation
- Automated threat containment
- Policy enforcement
- Encrypted traffic analytics

Cisco Confidential

Visibility and analytics

- Unified visibility
- Collaborate better than ever
- Accelerate threat investigation
- Reporting and audits
- Contextual visibility
- Actionable insights

Cisco Confidential

Automation and orchestration

- Maximise operational efficiency
- Automate workflows
- Block potential threats
- Optimise operations

Cisco Confidential

Some parts read more like philosophy than a science

We need to be SMARTer…

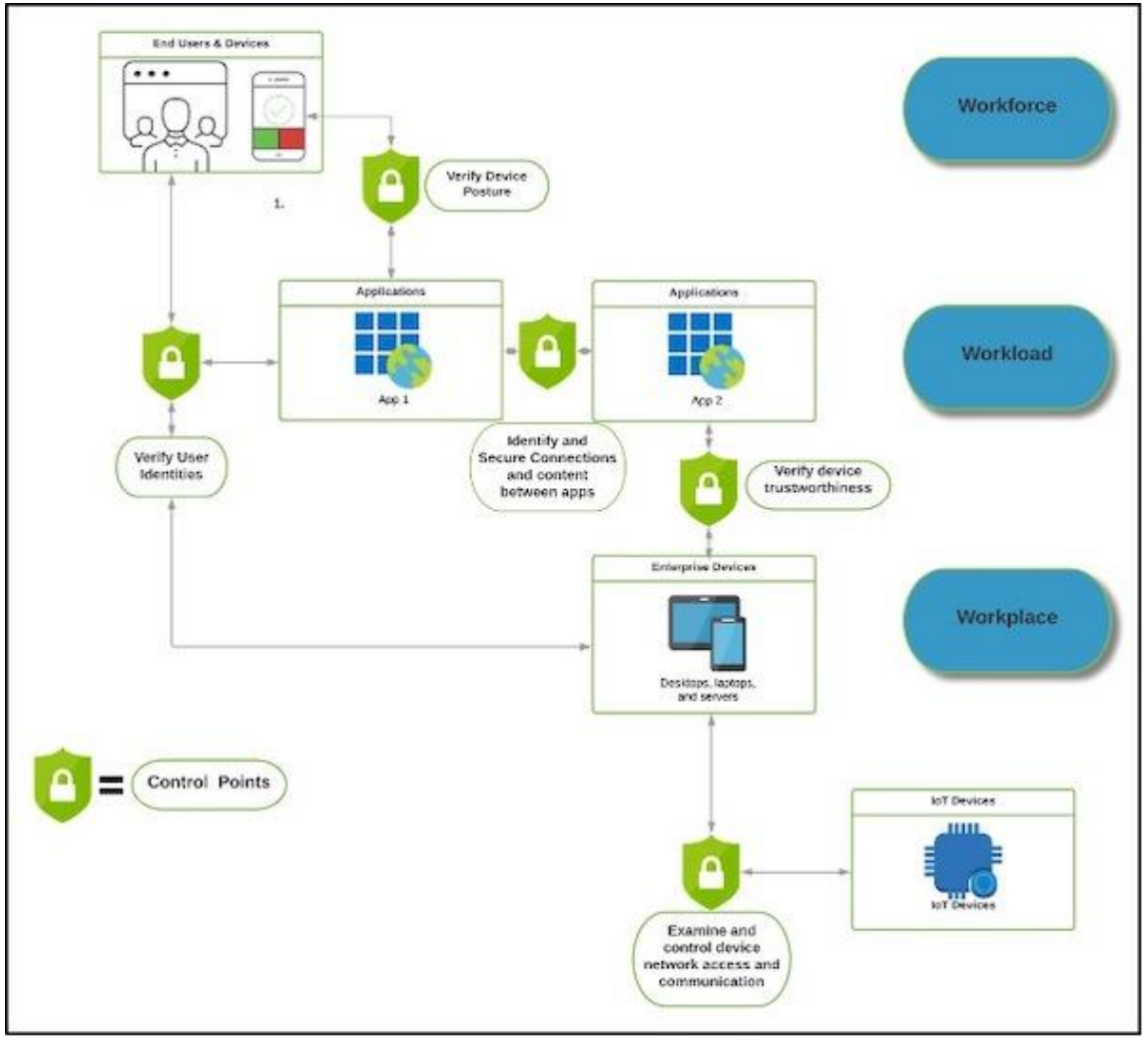
- **S**pecific: be clear about what each ZT property will deliver, and why it's important
- **M**easurable: the ZT property must be measurable to a defined standard
- **A**chievable: you must be able to deliver on the ZT property
- **R**elevant: the ZT property must affect something that matters and improves security
- **T**ime-Bound: the ZT property needs to be provable within a realistic time frame

Cisco Confidential

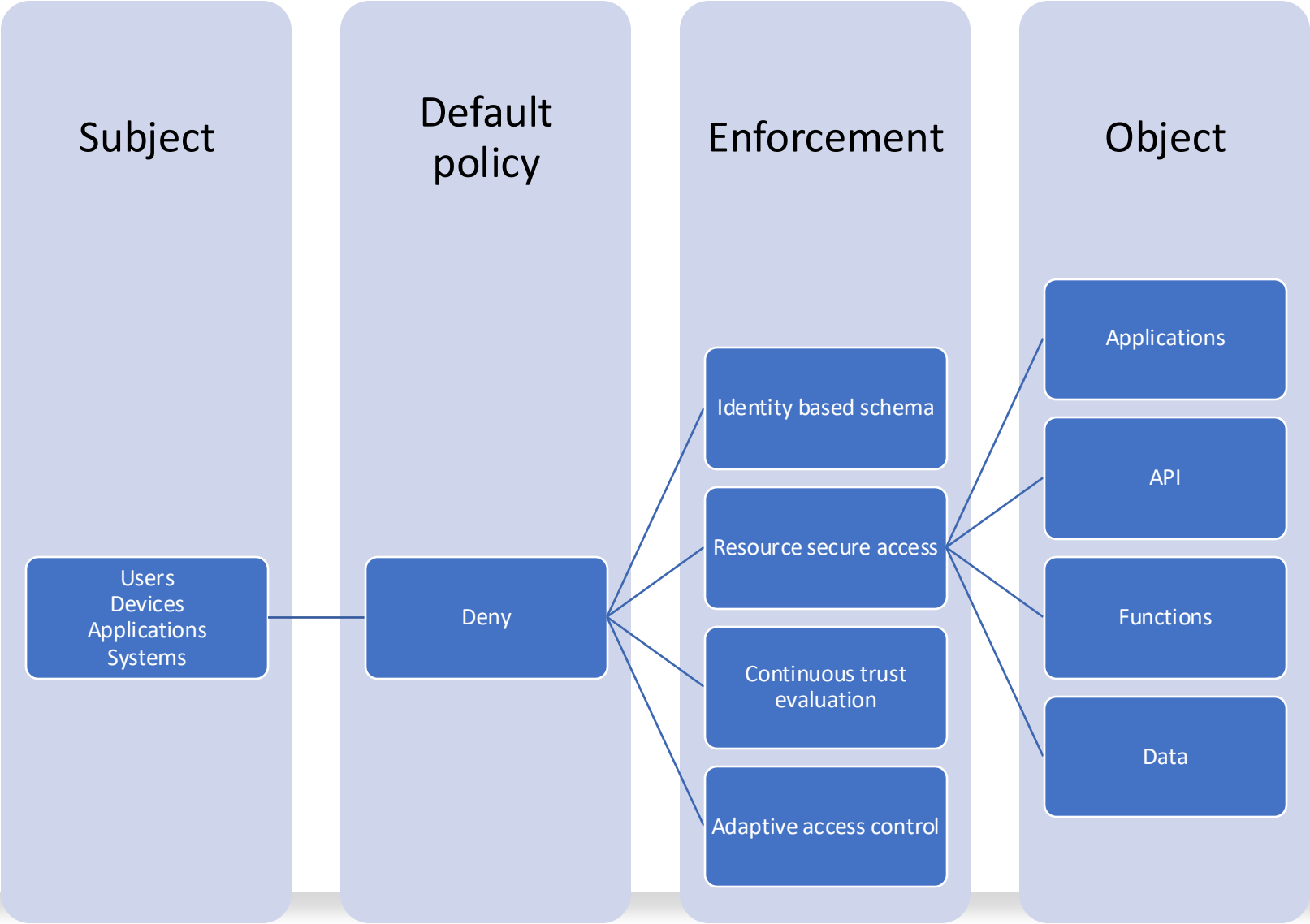
What components exist in a Zero Trust Architecture?

What might you want to attack?

Architectural diagram*



* courtesy of Duo


Subject
Default policy
Enforcement
Object
Users
Devices
Applications
Systems
Deny
Identity based schema
Resource secure access
Continuous trust evaluation
Adaptive access control
Applications
API
Functions
Data

Evaluating Zero Trust Architectures

What do we need to secure and against what?

Back in 2018…

- Dave ‘dwizzle’ Weston (Microsoft) proposed considering APT3 as a prototype threat group to evaluate Zero Trust
- Does this go far enough?
- Dave himself said:
  - Zero Trust is more of a philosophy than a well-defined security model or architecture
  - Identity is the new perimeter
  - Most vendors are overpromising security value, lots of low hanging fruit and room for improvement
  - Simultaneously re-architecting network for Zero Trust while moving to the cloud will enable you to take advantage of future improvements

Cisco Confidential

Persistence	Defense Evasion	Discovery	Collection	Command and Control	Exfiltration
Account Manipulation	Obfuscated Files or Information	File and Directory Discovery	Data from Local System	Ingress Tool Transfer	Exfiltration Over C2 Channel
		Permission Groups Discovery		Multi-Stage Channels	
		Process Discovery		Non-Application Layer Protocol	
		Remote System Discovery			
		System Information Discovery			
		System Network Configuration Discovery			
		System Network Connections Discovery			
		System Owner/User Discovery			

APT3

Reevaluating Dave’s threat model

- Apply Cisco’s Threat Modelling Service to the problem
  - What components do we see in the wild?
  - How might we attack them?
  - What evidence exists of attacks in the wild?
  - How do those attacks align to ATT&CK?
  - **Crucially, pulling it all back together – what do you need to be mindful of when you implement?**
    - **Channel**
    - **Collect**
    - **Contain**
    - **Detect**
    - **Disrupt**
    - **Facilitate**
    - **Legitimise**
    - **Test**

Cisco Confidential

Commercial realities

- What’s the product pitch?
  - Cloud
  - SASE et al
  - Microsegmentation
  - NAC
  - MFA
  - MDR (from a posture perspective)
- **Inherent vs potential**

Cisco Confidential

How do these stack up: Cloud

Inherent

- Automation and orchestration
- Visibility and analytics

Potential

- Data security
- Network security
- Workforce security
- Workload security

Cisco Confidential

How do these stack up: SASE et al

Inherent

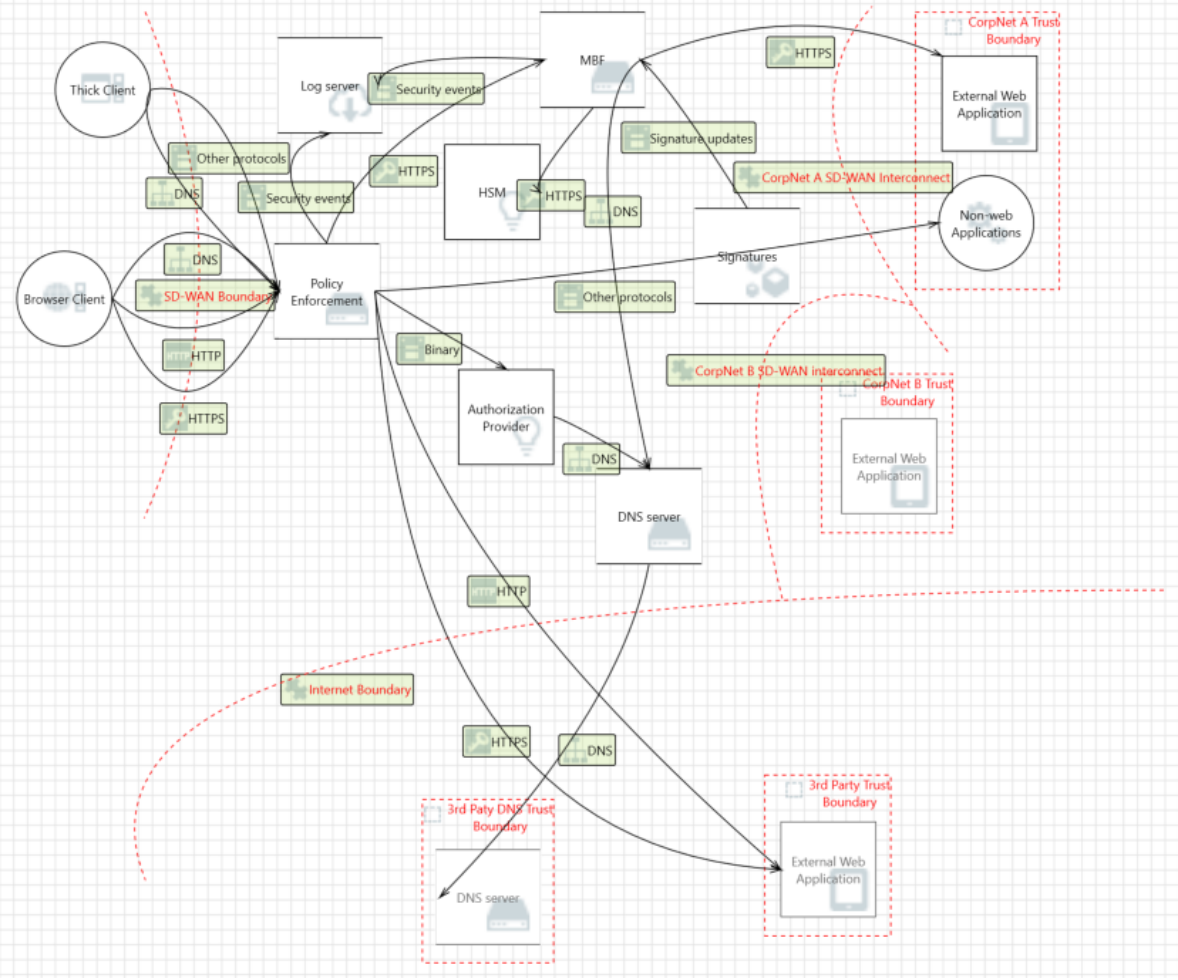
- Network security

Potential

- Data security
- Workforce security
- Workload security
- Automation and orchestration
- Visibility and analytics

Cisco Confidential

A quick tangent on MEF88 for SD-WAN application flow security*



* 94/113 threats in the current draft MEF88 threat model are deployment rather than vendor specific

How do these stack up: Microsegmentation

Inherent

- Data security
- Network security

Potential

- Workforce security
- Workload security
- Automation and orchestration
- Visibility and analytics

Cisco Confidential

How do these stack up: NAC

Inherent

- Network security

Potential

- Workforce security
- Visibility and analytics

Cisco Confidential

How do these stack up: MFA

Inherent

- Workforce security

Potential

- Data security
- Network security
- Workload security
- Automation and orchestration
- Visibility and analytics

Cisco Confidential

How do these stack up: MDR

Inherent

- Data security
- Workload security
- Workforce security

Potential

- Network security
- Automation and orchestration
- Visibility and analytics

Cisco Confidential

So what else could go wrong?

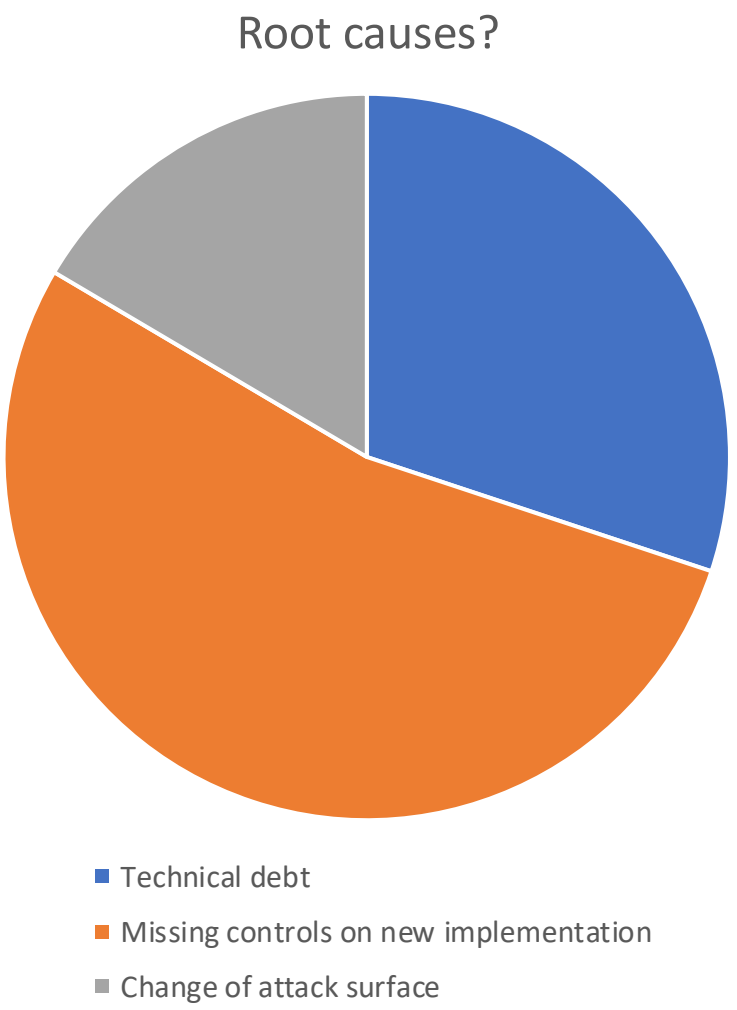
Critically, what *does* go wrong?

NIST 800-207

- ZTA vs ZTNA vs ZTAA
- Trust is layered
- Tenets and assumptions are helpful
- Focus on architectural patterns and variations
- High level threats considered
  - Subversion of decision
  - Denial-of-service
  - Stolen credentials/Insider threat
  - Visibility on the network
  - Storage of system and network information
  - Reliance on proprietary data formats or solutions
  - Use of non-person entities
- Starts to be measurable

Cisco Confidential

Critically, what *does* go wrong?



le Automation Forms

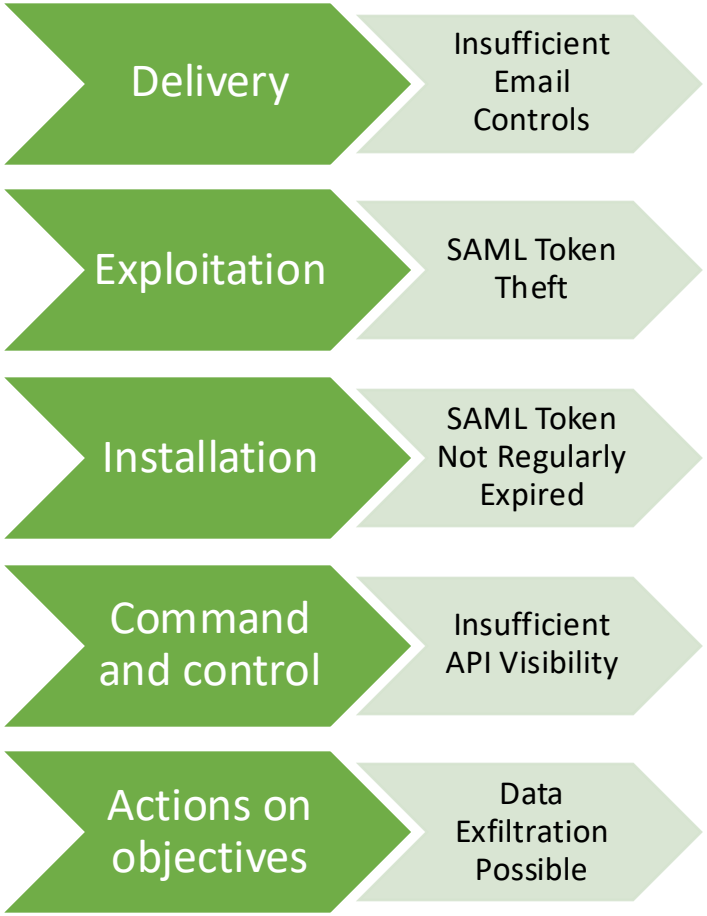
ZT TM Use Cases

Grid View Filter Arial 10

	ID	Area	Title	Finding	Industry
1	ZT0001	Automation	APIs Have Unnecessary Functionality		T1106
2	ZT0002	Automation	APIs Have Insecure Functionality		T1106
3	ZT0003	Identity	Breach Of Third Party IDP		T1207
4	ZT0004	Integration	Insufficient Technical Capability		
5	ZT0005	Integration	Insufficient Technical Capacity		
6	ZT0006	Visibility	Insufficient API Visibility		T1562.00
7	ZT0007	Visibility	Insufficient Endpoint Visibility		T1070.00
8	ZT0008	Visibility	Loss Of Network Visibility		T1205
9	ZT0009	Visibility	Loss Of Server Visibility		T1070.00
10	ZT0010	Identity	Mixing Of Trust Levels On Single IDP	http://www.harmj0y.net/	T1199
11	ZT0011	Policy	Service Exposed On Endpoint		T1595.00
12	ZT0012	Policy	Service Exposed On Server		T1595.00
13	ZT0013	Integration	Access Policies Misconfigured		T1553
14	ZT0014	Identity	Access Policies Not Maintained		T1553
15	ZT0015	Integration	API Access Policies Misconfigured	https://ermetic.com/wha	T1553
16	ZT0016	Identity	API Access Policies Not Maintained		T1553
17	ZT0017	Identity	Authentication Flows Without mTLS	https://support.microsof	T1573, T1

Mapping out the threats

Example attack path



https://github.com/timb-machine/zero-trust/issues

Cisco Confidential

What to map?

- Area
- Brief description of issue
- Reference to real world example
- Affected Zero Trust components
- Mapping to Cyber Kill Chain and ATT&CK for Enterprise
- Mapping to NIST 800-207 architectural patterns and variations
- Protocol?
- Authenticated?
- Capacity to detect?

Cisco Confidential

Technical debt

- By incorporating old into new, you risk contaminating things and enlarging the scope of the problem

To: it-leadership@bigcorp

Subject: Azure tenancy

We'd like to spin up an Azure tenancy for new systems after that last breach. We know we'll need to give everyone access. What Bob has suggested is that we join the tenancy to CORP, sync all the users and then firewall it off. Once all the users are on, we'll need to switch on MFA. Does this make sense?

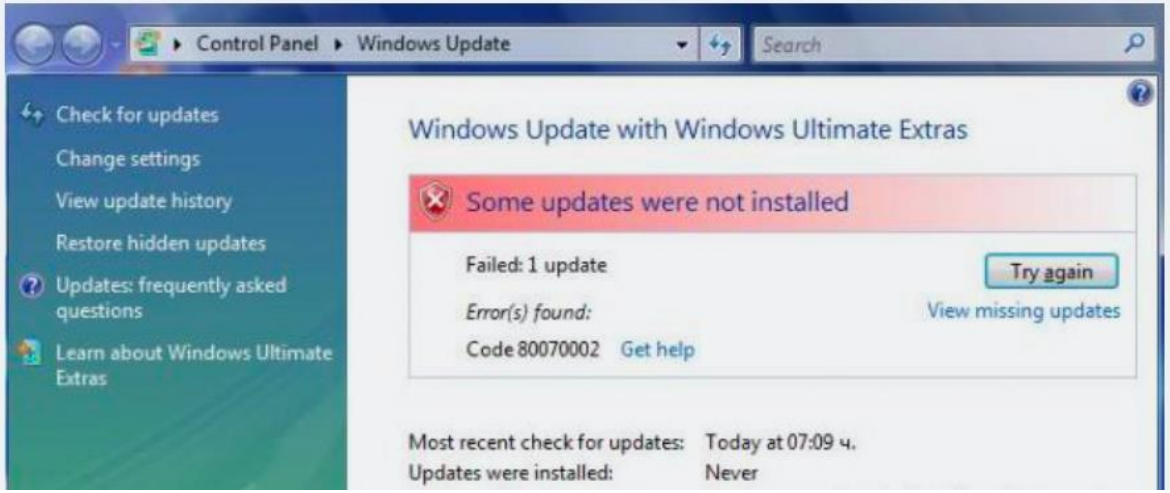
ZT64: IDP Store Breached

BIZ & IT —

“Flame” malware was signed by rogue Microsoft certificate

Emergency Windows update nukes credentials minted by Terminal Services bug.

DAN GOODIN - 6/4/2012, 8:59 AM



ZT46: PKI Misconfigured

Missing controls on new implementation

- If you're set on doing things differently, ensure you understand the technologies you're going to deploy and what controls will effectively mitigate the changes. That example on the previous slide, firewalls are great but sometimes they're not enough and with cloud, you might not even have that luxury

CLOUDFLARE The Cloudflare Blog

Thanks for being here, come back soon. Get notified of new posts:

Email Address Subscribe

Product News | Speed & Reliability | Security | Serverless | Zero Trust | Developers | Deep Dive | Life @Cloudflare

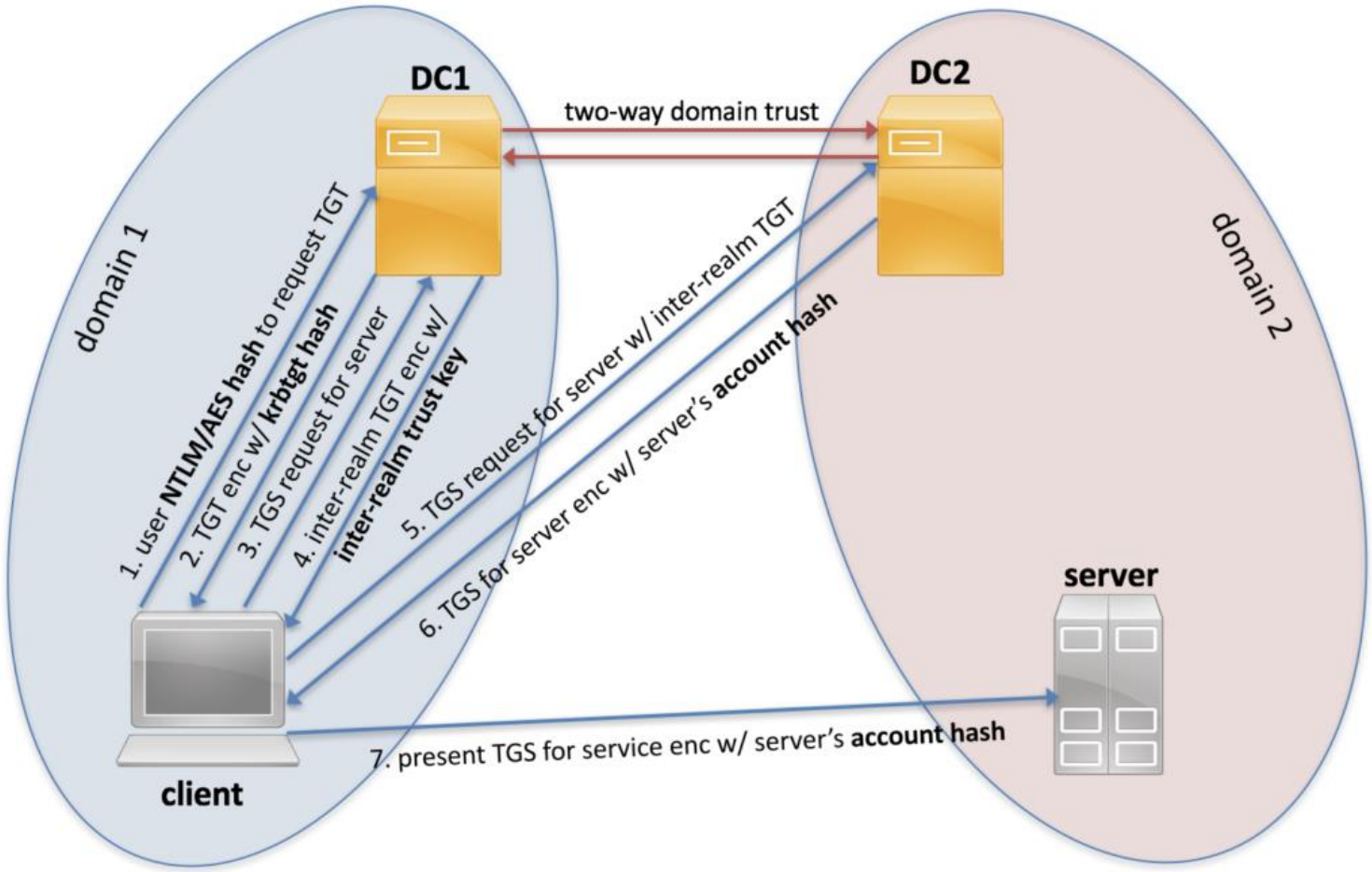
Padding oracles and the decline of CBC-mode cipher suites

12/02/2016

Nick Sullivan

At CloudFlare, we're committed to making sure the encrypted web is available to everyone, even those with older browsers. At the same time, we want to make sure that as many people as possible are using the most modern and secure encryption available to them. Improving the cryptography used by the majority requires a coordinated effort between the organizations building web browsers and API clients and those working on web services like CloudFlare. Cryptography is a two-way street. Even if we support the

ZT47: Insecure Cipher Selection



ZT10: Mixing Of Trust Levels On Single IDP

```
▶ Frame 44211: 601 bytes on wire (4808 bits), 601 bytes captured (4808 bits)
▶ Linux cooked capture
▶ Internet Protocol Version 4, Src: 66.249.64.143, Dst: 172.17.0.3
▶ Transmission Control Protocol, Src Port: 55962, Dst Port: 80, Seq: 1, Ack: 1, Len: 533
▼ Hypertext Transfer Protocol
  ▶ GET /diagram/1998-acura-wiring-diagram HTTP/1.1\r\n
    Host: ir.sicoobmetalcred.com.br\r\n
    AMP-Cache-Transform: google;v="1..5"\r\n
    Connection: keep-alive\r\n
    Accept: text/html,application/xhtml+xml,application/signed-exchange;v=b3,application/xml;q=0.9,*/*;q=0.8\r\n
```

ZT32: Insufficient Tenancy Governance

Name	OS	Version	Join Type	MDM	Compliant
[illegible]	Windows	10.0.18363.0	Azure AD joined	None	N/A
[illegible]	Windows	10.0.18363.0	Azure AD [illegible]ed	Microsoft Intune	No
[illegible]	Windows	10.0.18363.0	Azure AD jo[illegible]	[illegible]rosoft Intune	No
[illegible]	Windows	10.0.18363.0	Azure AD joined	M[illegible]ntune	Yes
[illegible]	Windows	10.0.18363.0	Azure AD joined	Microso[illegible]	No
SixByFour	Commodore	C64	Azure AD joined	Microsoft Intune	Yes
[illegible]	Windows	10.0.18363.0	Azure AD joined	Microsoft Intune	Yes
[illegible]	Windows	10.0.18363.0	Azure AD joined	Microsoft Intune	No
[illegible]	Windows	10.0.18363.0	Azure AD joined	Microsoft Intune	Yes
[illegible]	Windows	10.0.18363.1[illegible]	Azure AD joined	Microsoft Intune	No
[illegible]	Android	8.1.0		Microsoft Intune	N/A

ZT88: Conditional Access Not Enforced*

* https://o365blog.com/post/mdm/

```
timb@mfa1:~ $ cat recovery.rec
12345
12312
31337
00789
11111
timb@mfa1:~ $ ls -l recovery.rec
-rw-r--r--  1 timb  staff  30 16 Jun 02:11 recovery.rec
timb@mfa1:~ $
```

ZT102: Recovery Code Theft*

* any resemblance to how a particular product stores Google Authenticator recovery tokens is purely illustrative

Change of attack surface

- Just because you're putting something into the cloud doesn't necessarily make it better. If before, your attacker needed a logical vantage point inside your perimeter or better still, perhaps you'd not let them in to begin with, in many implementations of cloud hosted apps, document.cookie is enough, *wherever* your adversary chooses to live

GAMES BY VICE

How Hackers Used Slack to Break into EA Games

A representative for the hackers explained to Motherboard how the group stole a wealth of data from the game publishing giant.

By Joseph Cox

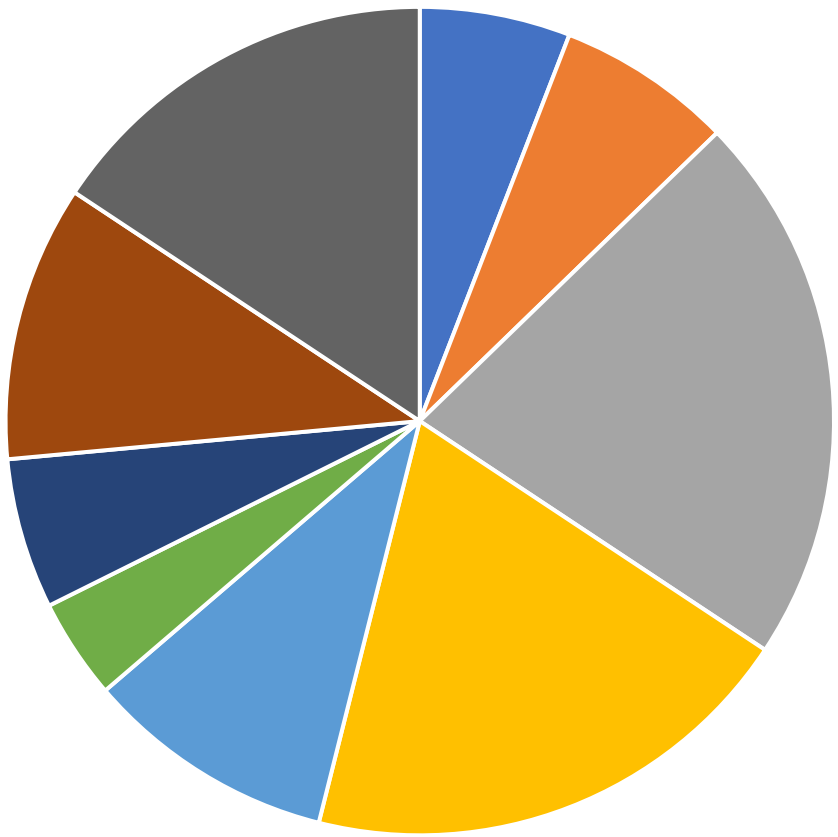
11.6.21 Share Tweet Snap

MORE LIKE THIS

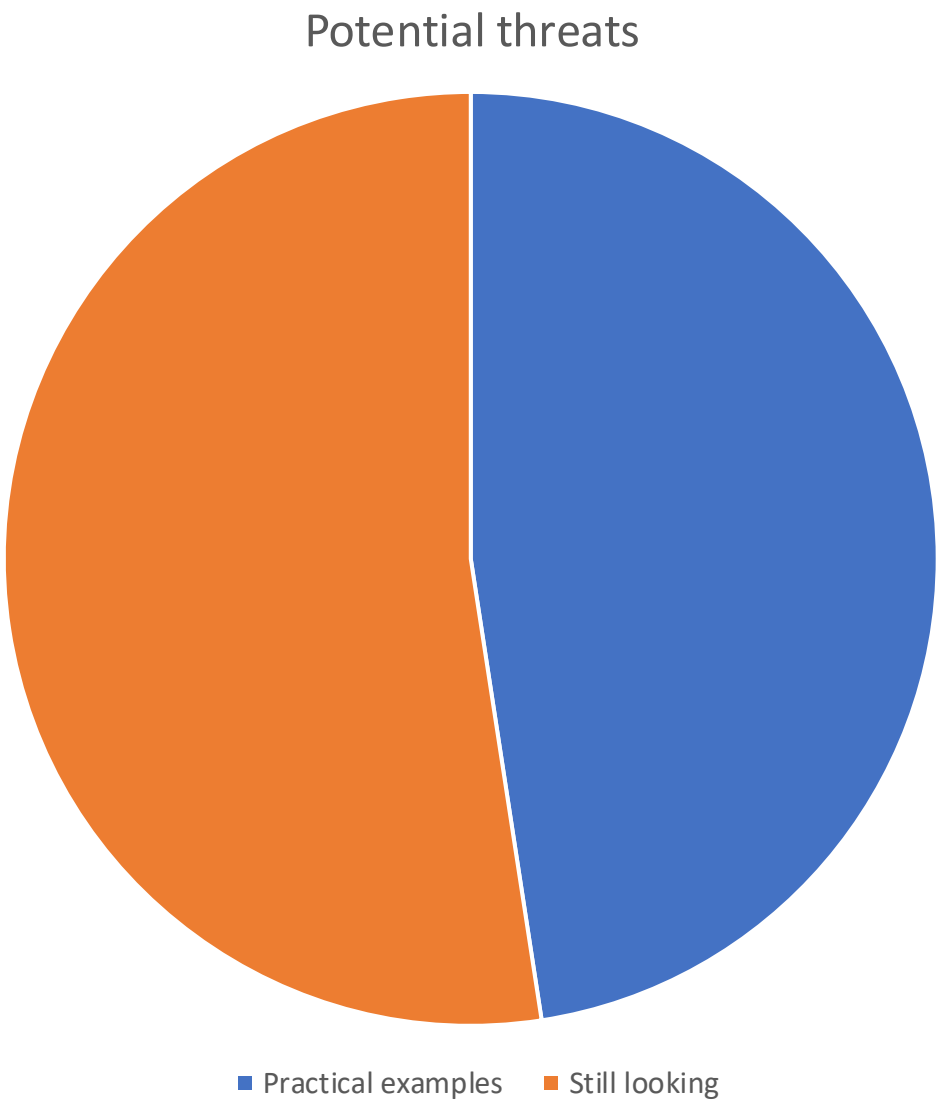
Games

ZT101:
Cookie Theft

What attack surfaces did I consider and to what degree?



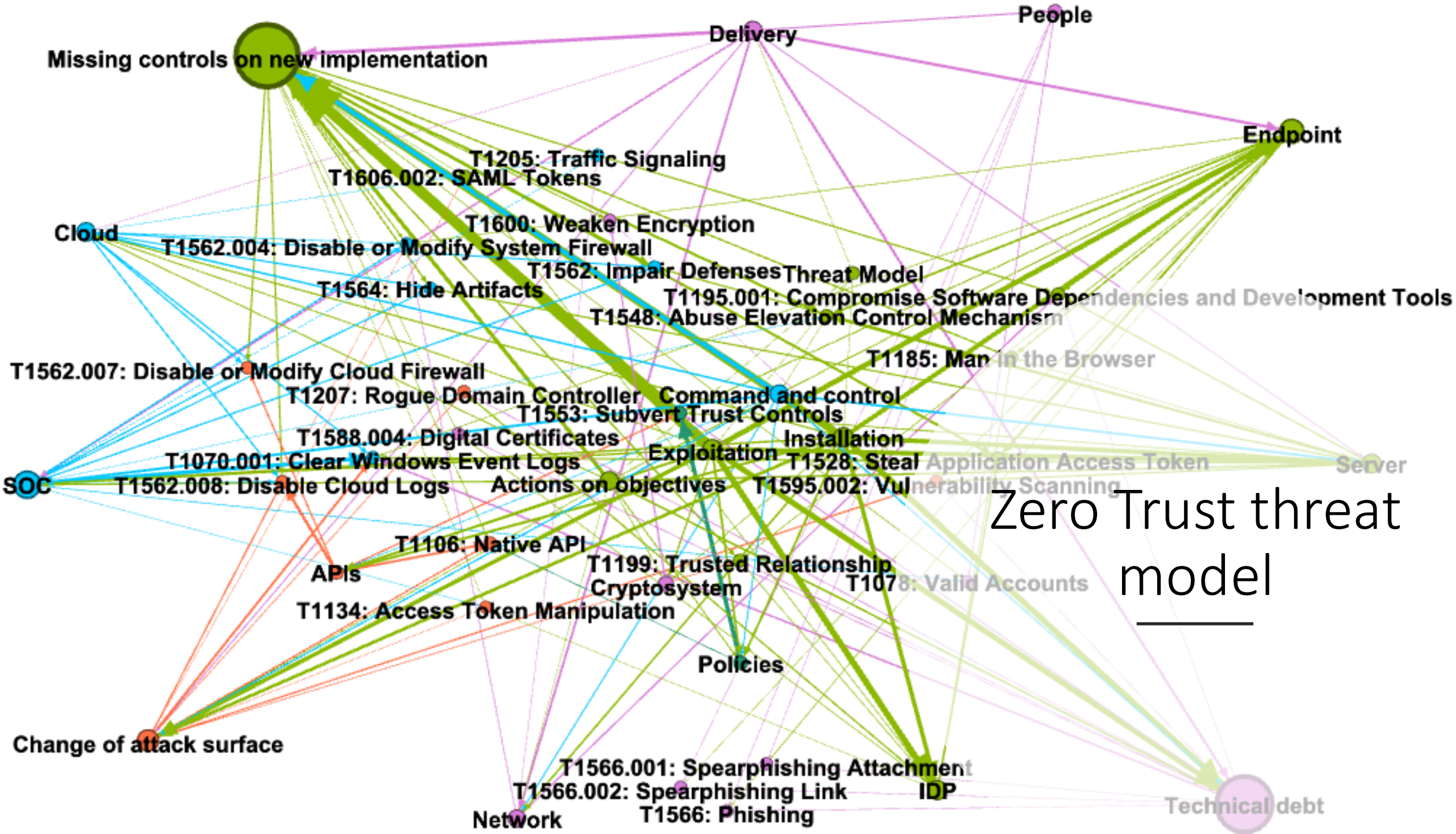
So just how likely are the threats?



It’s not that Zero Trust is a bad idea…

Rather that reducing Zero Trust down to a bunch of buzz words makes it sound easy, masks critical complexities and persuades people that magic boxes really do exist.

Trust but Verify *everywhere*.



Zero Trust threat model

Questions to ask yourself

- What am I trying to secure?
- Do I own it?
- Is this a priority? How critical is this?
- How deep into the network are we talking?
- What controls am I reliant on?
- Are those controls themselves secure?
- How would I attack them?
- What would the impact of this be?

Cisco Confidential

So what *would* make things better?

Zero Trust

- Data security
- Network security
- Workforce security
- Workload security
- Automation and orchestration
- Visibility and analytics

Cyber Hygiene

- Don’t put all your identity eggs in one basket
- Continue to apply network level access controls wherever possible
- Clean up your Active Directory forest
- Choose secure by default, from procurement+language up and patch
- Leverage devops to standardise and clean up all that ”old” stuff
- Ensure you’re pulling (and reading) logs from XaaS

Cisco Confidential

Questions?

twadhwab@cisco.com

Cisco Confidential

Bonus material

Cisco Confidential

References

- **https://github.com/timb-machine/zero-trust**
- https://www.ncsc.gov.uk/collection/zero-trust-architecture
- https://csrc.nist.gov/publications/detail/sp/800-207/final
- https://github.com/dwizzzle/Presentations/blob/master/David%20Weston%20-%20Zer0ing%20Trust%20-%20Do%20Zero%20Trust%20Approaches%20Deliver%20Real%20Security.pdf
- https://mitre-attack.github.io/attack-navigator//#layerURL=https%3A%2F%2Fattack.mitre.org%2Fgroups%2FG0022%2FG0022-enterprise-layer.json